

Capstone Project

Final Report

Web Application Penetration Testing and Security Assessment of DVWA

Executive Summary

This project assessed the security posture of DVWA (Damn Vulnerable Web Application) within a controlled laboratory environment. Multiple OWASP Top 10 vulnerabilities were identified, exploited, and analyzed. Mitigation strategies were proposed to reduce the identified risks.

1. Introduction

Objective

To identify and assess common web application vulnerabilities using DVWA and demonstrate mitigation techniques.

Scope

- SQL Injection
- Stored XSS
- Reflected XSS
- CSRF
- File Inclusion
- Burp Suite Testing

- Security Headers Assessment

Tools Used

- Kali Linux
- DVWA
- Burp Suite
- Firefox
- Apache
- MySQL
- GitHub

2. Methodology

The project followed a standard penetration testing methodology:

1. Planning
2. Reconnaissance
3. Vulnerability Assessment
4. Exploitation
5. Mitigation
6. Reporting

[Insert Network Diagram]

3. SQL Injection Assessment

Description

SQL Injection vulnerabilities were assessed using DVWA.

Attack

Payload:

1' OR '1'='1'#

Findings

Multiple database records were returned due to insufficient input validation.

Risk

High

Mitigation

- Prepared Statements
- Parameterized Queries
- Input Validation

[Insert SQLi Screenshots]

4. Cross Site Scripting Assessment

Stored XSS

Payload:

```
<script>alert('Stored XSS')</script>
```

Reflected XSS

Payload:

```
<script>alert('Reflected XSS')</script>
```

Risk

Medium

Mitigation

- Content Security Policy
- Output Encoding
- Input Validation

[Insert XSS Screenshots]

5. Cross Site Request Forgery Assessment

Attack

Unauthorized password change using forged requests.

Risk

Medium

Mitigation

- CSRF Tokens
- SameSite Cookies
- User Verification

[Insert CSRF Screenshots]

6. File Inclusion Assessment

Local File Inclusion

Sensitive local files were accessible.

Remote File Inclusion

Not demonstrated due to PHP security restrictions.

Risk

High

Mitigation

- File Whitelisting

- Input Validation
- Disable allow_url_include

[Insert File Inclusion Screenshots]

7. Burp Suite Testing

Activities

- Intercept Requests
- Modify Requests
- Intruder Testing

Findings

Input manipulation was possible through intercepted requests.

Mitigation

- Server Side Validation
- Rate Limiting
- MFA

[Insert Burp Suite Screenshots]

8. Security Headers Assessment

Findings

Several security headers were missing.

Recommended Headers

- Content Security Policy
- X-Frame-Options
- X-Content-Type-Options
- Referrer Policy

[Insert Security Headers Screenshots]

9. Incident Response Simulation

Detection

Malicious SQL Injection activity identified.

Containment

Input validation controls implemented.

Eradication

Vulnerable code corrected.

Recovery

Application functionality restored and tested.

Lessons Learned

Regular security testing improves overall security posture.

10. Recommendations

1. Use Prepared Statements.
2. Validate user input.
3. Implement CSP.
4. Deploy CSRF protections.
5. Restrict file inclusion functionality.
6. Apply security headers.
7. Conduct regular vulnerability assessments.

11. Conclusion

The assessment successfully demonstrated multiple web application vulnerabilities and their corresponding mitigation strategies. Secure development practices significantly reduce the risk associated with common web application attacks.